

SIH26106 · EMAIL THREAT · GEO · FORENSICS

MailTrace

Complete teammate guide — what we built, every term, and the screenshots that prove it.

This PDF is the whole story in one file. You do not need GitHub to walk someone through it. The live lab is a local-first analyst tool: upload a saved **.eml**, get a score, reasons, hop map, campaign graph, hashed evidence, and a case PDF.

It is not Gmail. It does not read inboxes. It does not send phishing. Geo is hosting city / ISP of a mail server, not a person's GPS.

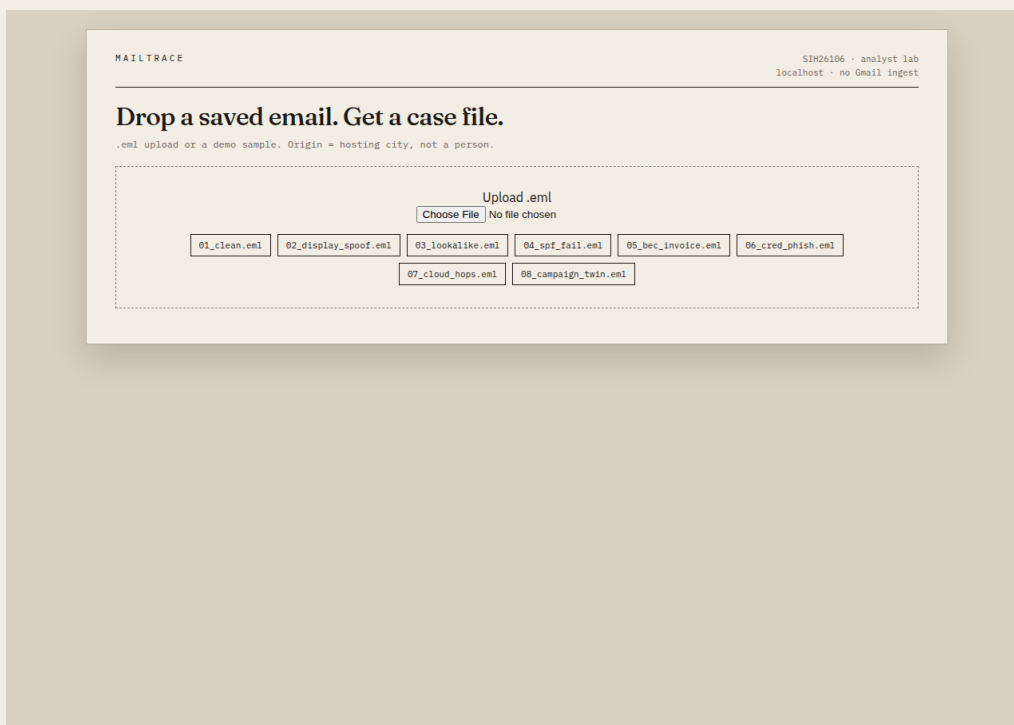


Figure 1 — Landing page. Sample chips + .eml upload.

1. What it is, in one minute

Give MailTrace a saved email. It answers five questions:

1. Is it shady? Score 0–100 and a label: CLEAN, SPOOF, PHISH, or BEC.
2. Why? Plain reasons such as SPF fail or Reply-To ≠ From.
3. Where did it travel? The Received hop chain and the probable first public hop.
4. Is it part of a campaign? A graph linking emails that share Reply-To / domain / hop.
5. Proof? SHA-256 of the exact uploaded bytes + a downloadable PDF case file.

Think: post-mortem lab, not a spam filter.

2. Why this exists

SIH26106 asks for an AI-powered platform that detects fraudulent email and helps an investigator explain origin and campaign links. Real pain: a mail that looks like Exam Cell but came from a rogue host; a vendor asking to wire money to a new account (BEC); spam filters that only say spam/not-spam.

So we built an explainable laptop lab. No Gmail login required. Teammates can demo it from a saved file.

3. What it is not

Not a trained 99% spam classifier. Not Gmail/Outlook ingest. Not a human tracker. Not full DKIM cryptographic verification (we read header stamps, and we can look up live SPF/DMARC TXT). Not court-grade chain of custody. Not “we found the attacker.” The score is a risk indicator, not a probability.

4. Run it on your own PC (from GitHub)

The code is on GitHub: <https://github.com/nexurlabs/sih> (public). Clone it, then follow the Windows steps below. Mac/Linux notes are at the end of this section. You do not need the IBM VM. You do not need Gmail.

Step A — install three things (once)

1. **Python 3.11 or 3.12** from python.org → Downloads → Windows. On the installer, tick **Add python.exe to PATH**. Finish, then close PowerShell if it was open and open a new one.
2. **Git** from git-scm.com (Next, Next, Next is fine). Or install GitHub Desktop if you hate terminals.
3. Confirm Python works:

```
python --version
# expect: Python 3.11.x or 3.12.x
```

If that says “not recognized”, PATH was not ticked. Reinstall Python and tick the box.

Step B — clone the repo

In PowerShell:

```
cd $HOME\Desktop
git clone https://github.com/nexurlabs/sih.git
cd sih
```

GitHub Desktop: File → Clone repository → nexurlabs/sih → clone to Desktop, then open that folder in a terminal.

Step C — make a venv (do not skip)

A venv is a private Python just for this project, so you do not wreck other stuff.

```
python -m venv .venv
.\.venv\Scripts\Activate.ps1
```

If PowerShell screams about execution policy, run this once, then Activate again:

```
Set-ExecutionPolicy -Scope CurrentUser RemoteSigned
```

CMD instead of PowerShell: run `.\venv\Scripts\activate.bat`. You should see **(.venv)** at the left of the prompt.

Step D — install, test, start

```
pip install -r requirements.txt
python scripts\write_samples.py
python scripts\train_nlp.py
pytest -q
python -m uvicorn app:app --host 127.0.0.1 --port 8777
```

Leave that window open. Open Chrome/Edge and go to **<http://127.0.0.1:8777>** — that is your copy, on your laptop. Stop it later with Ctrl+C in the same window. After Activate you can also run `.\run.ps1`.

If python opens the Microsoft Store instead of Python, use `py -3` in every command (`py -3 -m venv .venv`, `py -3 -m uvicorn ...`).

Step E — click the demo (this is how you use it)

1. Click **04_spf_fail.eml** → stamp should be **64 / SPOOF**. Point at SPF/DKIM/DMARC fail and Frankfurt (hosting, not a person).
2. Click **01_clean.eml** → **8 / CLEAN**. Same engine, honest low score.
3. Click **07_cloud_hops.eml**, then **08_campaign_twin.eml** → those two dots get one line (campaign candidate).

Extra samples just add more dots.

4. Scroll: Local NLP box, Live DNS (SPF/DMARC TXT), origin map, evidence hash, Download case PDF.

5. Optional: upload any saved .eml (Gmail → three dots → Show original → Download).

If pytest is red, or the page will not open, you skipped Activate or the uvicorn window died. Start Step D again from pip.

Optional: live DNS + GeoIP + Qwen

In the **same** PowerShell window, before uvicorn (Windows does not auto-read .env unless you use Git Bash + ./run.sh):

```
$env:MAILTRACE_LIVE_DNS="1"
$env:MAILTRACE_LIVE_GEO="1"
python -m uvicorn app:app --host 127.0.0.1 --port 8777
```

MaxMind .mmdb files are gitignored (they are big / licensed). Demo IPs still pin Frankfurt. For random real IPs, put GeoLite2-City.mmdb (and optionally ASN) in data/ — ask a teammate for the files, do not commit them.

Qwen is optional. Score works without it:

```
python scripts\set_groq_key.py
```

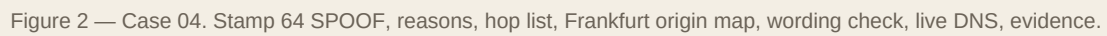
Mac / Linux (same idea)

```
python3 -m venv .venv
source .venv/bin/activate
pip install -r requirements.txt
python scripts/write_samples.py
pytest -q
python -m uvicorn app:app --host 127.0.0.1 --port 8777
```

Do not: connect Gmail, send phishing, claim you located a person, or push secrets / .env / .mmdb.

5. How to use it (30 seconds, once it is open)

Open the app → click **04_spf_fail.eml** → you should see **64 / SPOOF**. Then click **07_cloud_hops.eml** and **08_campaign_twin.eml** → the graph shows two nodes and one edge. Download the case PDF. On the private host you can also drop a real saved .eml.



6. What the app looks like

Same screens you get after you start the app and click a sample.

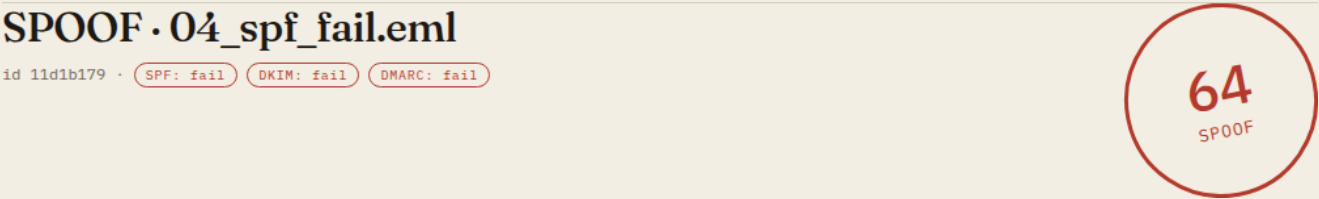


Figure 3 — Case header: 64 SPOOF, SPF/DKIM/DMARC fail pills.

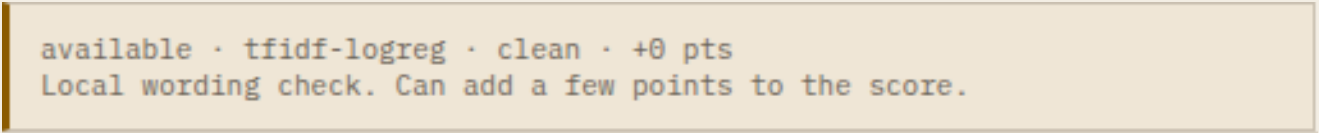


Figure 4 — Local wording check. Reads the email text and can add a few points to the score.

ENABLED true	SPF PUBLISHED absent
DMARC PUBLISHED absent	HOP IN SPF not-evaluated

Figure 5 — Live DNS. pec.edu.in has no published SPF/DMARC TXT (absent). That is a real finding, not a lookup bug.

SOURCE message-header	VERIFICATION MODE header-stated
INDEPENDENT DKIM CRYPTO no	

Figure 6 — Auth source vs live DNS. Header-stated = what the .eml already said. Independent DKIM crypto = no.

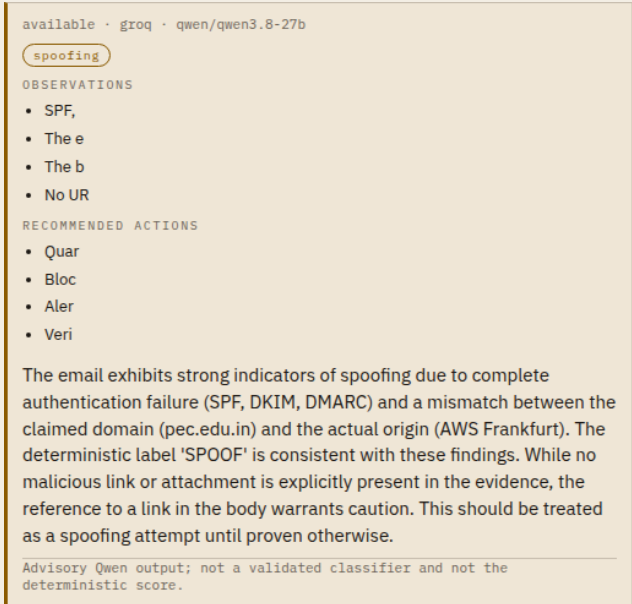


Figure 7 — Qwen analyst assist. Advisory only. It cannot change the score or label. Mentions AWS Frankfurt as hosting.

Campaign graph — 07 then 08

Reset the lab, analyse 07_cloud_hops.eml, then 08_campaign_twin.eml. They share Reply-To + hop + domain, so the graph draws exactly two nodes and one edge. Shared indicators = campaign candidate. Not proof of the same human.

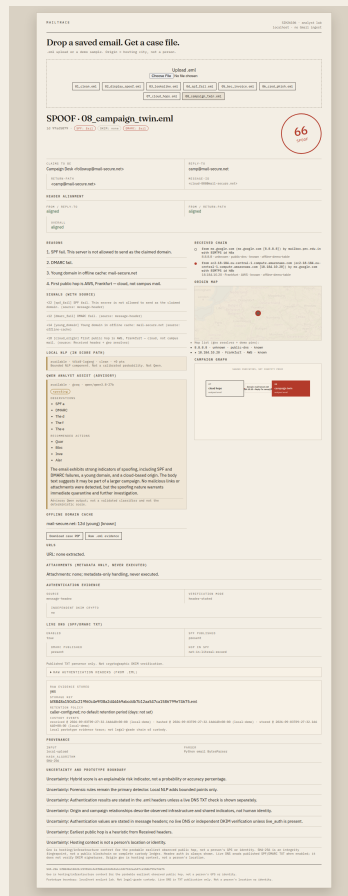


Figure 8 — Full case with campaign graph after 07 + 08.

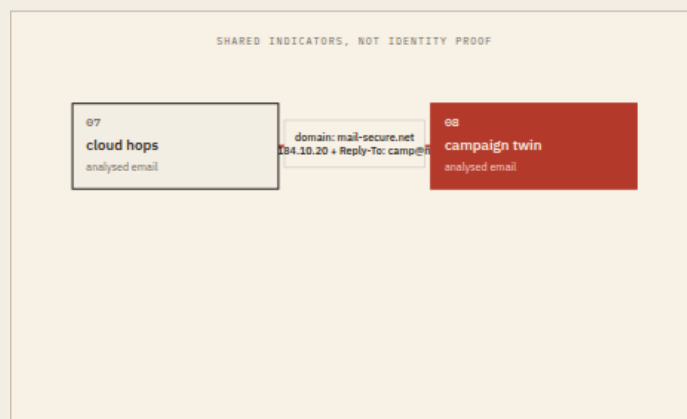
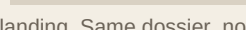


Figure 9 — Graph close-up. Shared domain / hop / Reply-To. Not proof of the same human.

[illegible]

7. Every term, in plain language

.eml

A saved email file. Full headers + body. Gmail: Show original → Download.

From / To / Subject

Who claims to send, who receives, the title. Easy to fake.

Reply-To

Where a reply actually goes. Scam trick: From looks official, Reply-To is a Gmail.

Return-Path

Where bounces go. Should match From. Mismatch is a signal.

Message-ID

A unique-ish id stamped by a mail system. Useful in evidence, not identity.

Received chain

Each server that touched the mail adds a Received line. Read from the bottom up. The last public hop is our heuristic “origin.”

Public hop

A Received IP that is not 127.x / 10.x / 192.168.x. Those private ones are internal.

SPF

Sender Policy Framework. The domain publishes which servers may send as it. Fail = this server is not on the list.

DKIM

A signature in the headers. We report the header-stated result. We do not re-check the crypto.

DMARC

Domain policy: what to do if SPF/DKIM fail. Fail = the domain’s own policy was violated.

Header-stated vs live DNS

Header-stated = what the .eml already says. Live DNS = we query TXT for SPF and _dmarc. Live is publication, not DKIM crypto.

Alignment

Do From, Reply-To, and Return-Path domains match? Mismatch is a spoof cue.

Lookalike domain

paypa1 vs paypal, pec-edu.in vs pec.edu.in. Eyes miss it.

BEC

Business Email Compromise. Urgent payment / new bank account. Often no malware, just pressure.

Phish

Credential theft. Verify password, login to continue, account suspended.

Spoof

Fake sender identity. The envelope lies.

Score 0–100

Risk meter. Starts at 8, adds points per signal. 64 is not “64% sure.”

Forensic score

The rule-based part only (SPF, Reply-To, keywords, cloud hop...).

NLP

Local wording model (TF-IDF + logistic regression). Reads the email text and can add a few points to the score. Different tool from the optional Qwen notes.

Qwen / Groq

Optional LLM notes. Redacted input. Never changes the stamp.

Label

CLEAN < 45. SPOOF from header/auth. BEC if payment language. PHISH if password/lookalike + high score.

Signal

One finding with points and a source, e.g. spf_fail +22 from message-header.

Young domain

Offline WHOIS cache says the domain is newly registered. Burner domains.

Cloud origin

First public hop is AWS/GCP/Azure-class, not campus mail.

GeoIP / MaxMind

IP → city / ISP / ASN from a local MMDB. Hosting context. Not GPS of a person.

Demo IP table

Five IPs baked into the sample .emls so 04 always shows Frankfurt. Real uploads use MaxMind.

Campaign graph

NetworkX. Dots = emails. Line = shared Reply-To / domain combo. Never IP-only. Never “same person.”

SHA-256

Fingerprint of the exact file you uploaded. One byte change → different hash.

Custody events

Local log: received → hashed → stored. Prototype, not legal-grade.

Masked view

Emails shown as j***@domain so you can share a case without the full address.

Deterministic

Same .eml, same forensic score. No dice rolls.

Public demo vs private

Public path is read-only samples. Private (auth) allows upload, PDF, evidence.

8. The eight demo emails (pinned results)

These files live in samples/. They are crafted so a judge can see each threat class. The engine is the same as for a real upload.

file	score	label	what it teaches
01_clean.eml	8	CLEAN	Normal mail, aligned auth
02_display_spoof.eml	100	SPOOF	Gmail wearing an official title
03_lookalike.eml	98	PHISH	paypa1-style lookalike + login lure
04_spf_fail.eml	64	SPOOF	Server not allowed to send as pec.edu.in
05_bec_invoice.eml	100	BEC	Urgent wire / new bank account
06_cred_phish.eml	100	PHISH	Verify password + urgency (+ NLP)
07_cloud_hops.eml	66	SPOOF	First hop is cloud, not campus
08_campaign_twin.eml	66	SPOOF	Twin of 07; graph links them

After 07 + 08: graph = 2 nodes, 1 edge. 01 + 04 do not link just because both mention pec.edu.in.

9. What happens to one email (04)

From looks like Exam Cell <notice@pec.edu.in>. Received shows rogue.example [18.184.10.20]. Authentication-Results: SPF/DKIM/DMARC fail.

Pipeline: .eml bytes → parse_eml (headers, body, URLs, attachment metadata) → offline WHOIS cache → optional live SPF/DMARC TXT → fuse (base 8 + SPF 22 + DKIM 12 + DMARC 12 + cloud 10 = 64) → label SPOOF → NLP adds 0 on this file → Qwen note (advisory) → SQLite + hashed evidence → NetworkX graph → PDF on demand.

Why not 100? No password lure, no invoice language, no lookalike. Honest: bad auth, not a credential trap.

10. Stack (what we actually coded in)

piece	what	why
Language	Python 3	Email + tests + ML libs
API	FastAPI + Uvicorn	Tiny /api/analyze, health, PDF
Parser	stdlib email + parse.py	MIME, hops, HTML hrefs
Score	score.py rules	Explainable; same file → same forensic score
NLP	sklearn TF-IDF + LogReg	Bounded wording points, local corpus
Graph	NetworkX	Campaign candidates
Store	SQLite + SHA-256 files	Laptop, no extra server
PDF	ReportLab	Case file download
UI	HTML + JS	No React build
Map	Leaflet + hop list	Tiles optional; list always works
Geo	MaxMind MMDB	Real IPs get city/ISP
Live DNS	dnspython	SPF/DMARC TXT when online
Assist	Groq Qwen	Sidebar only
Tests	pytest (46+)	Pins 04=64, 07+08 graph, auth conflict

11. Two-minute demo script for teammates

1. “This is MailTrace. Offline email forensics. No Gmail.”
2. Open 04 → 64 SPOOF. Point at SPF/DKIM/DMARC fail and Frankfurt hop (hosting, not a person).
3. Open 01 → 8 CLEAN. Same engine, honest low score.
4. Reset, then 07 then 08 → two nodes, one edge. Campaign candidate.
5. Evidence / PDF → hashed original bytes.
6. Close: “Rules decide. NLP adds a bit. Qwen only explains. Geo is a server.”

12. Limits to say out loud

Demo .emls are crafted. WHOIS is an offline cache. DKIM is not re-verified cryptographically. NLP is uncalibrated. pec.edu.in currently has no SPF TXT (live DNS will say absent — that’s a real finding). No mailbox gateway, no quarantine, no “we geolocated a human.”

That’s the whole product. If they can click 04 and then 07+08 and repeat the terms above, they can present it without you in the room.